PRD Credit Score Check

1. Objective

a. BoltPe will offer a free "**Credit Score Check**" tool inside the app.
b. A logged-in user submits their identity details, verifies ownership of their registered mobile number via an OTP, and receives their Experian credit score together with a readable interpretation and a downloadable credit report.
c. The score and report are sourced from BoltPe's KYC vendor (KYC-Flow) through the Credit Score Check API v4. (**Vendor: Invincible Ocean**)
d. BoltPe does not compute the score; it orchestrates consent capture, OTP verification, and presentation of the vendor response.

2. Goals

a. Give app users free, on-demand visibility of their credit score with minimal input friction.
b. Enforce explicit consent and mobile-ownership verification (OTP) before any bureau data is pulled.
c. Present the score in a clear, band-based, non-technical format, plus a full downloadable report.
d. Establish a reusable, auditable integration pattern with the KYC-Flow bureau API.

3. Scope

a. Entry point (tile/ banner) in the app for eligible logged-in users.
b. Consent screen and details capture (with prefill from the user's BoltPe profile/ KYC where available).
c. OTP generation via the vendor and OTP verification.
d. Score fetch, band interpretation, and score display screen.
e. Credit report generation (PDF) and download/ share.
f. Error, empty, and retry states across the flow.

4. Eligibility

a. Please Note:

i. Application user shall only be able to check their own Credit Score. The user shall not be able to see someone else's credit score.

5. User & pre-conditions

Pre condition	Requirement
Authentication	User is logged in to BoltPe with a verified account.
Registered mobile	Account has a verified mobile number; OTP is sent only to this number.
Minimum data	First name, last name, PAN, DOB, mobile, email, gender, and PIN code are available or can be entered.
Consent	User must actively provide consent before the pull
Age / PAN validity	User is an adult with a valid PAN (bureau data keyed on PAN).

---

6. End to End Flow

a. The flow below is the reference for Design.

b. Visual and interaction design are intentionally left open; this section defines steps, decision points, and the states each screen must support.

c. Happy Flow:

i. Entry:

1. User taps the "**Check Credit Score; Free**" entry point.

ii. Intro/ Value:

1. Brief explainer: what they'll get, that it's free, and that it will not affect their score (soft enquiry).

iii. Consent & details:

1. Show details form (prefilled where possible). User reviews/edits fields and gives explicit consent.

iv. Request OTP:

1. App calls the vendor genOtp endpoint. OTP is sent to the registered mobile.

v. Verify OTP:

1. User enters OTP; app verifies with the vendor and triggers the score/report pull.

vi. Processing:

1. Loading state while the vendor returns the bureau report.

vii. Score result:

1. Display score, band, and summary highlights, with a CTA to download the full report.

viii. Report:

1. User downloads/shares the generated PDF credit report.

---

7. Screens & States

a. Screen:

i. Entry Point

ii. **Purpose:** Launch the flow

iii. **Required States:** Default; Hidden (Ineligible/ Guest)

b. Screen:

i. **Intro / Value**
ii. **Purpose:** Set expectations & consent framing
iii. **Required States:** Default

c. S**creen:**
i. **Details & consent**
ii. **Purpose:** Capture/confirm inputs + consent
iii. **Required States:** Default; Field validation error; Consent-not-given (CTA disabled); Submitting

d. **Screen:**
i. **OTP entry**
ii. **Purpose:** Verify mobile ownership
iii. **Required States:** Default; Resend cooldown; Invalid OTP; Expired OTP; Max attempts reached; Verifying

e. **Screen:**
i. **Processing**
ii. **Purpose:** Await bureau response
iii. **Required States:** Loading; Timeout >> Retry

f. **Screen:**
i. **Score result**
ii. **Purpose:** Show score + band + highlights
iii. **Required States:** Success; No-hit/ Data-not-found; Partial data; Error

g. **Screen:**
i. **Report**
ii. **Purpose:** Deliver downloadable report
iii. **Required States:** Ready; Generating; Download failed

h. **Screen:**
i. **Generic Error**
ii. **Purpose:** Recover from failures
iii. **Required States:** Retryable; Non-retryable; Rate-limited

---

8. Functional Requirements

a. Entry & Eligibility

i. The entry point Must be visible only to authenticated users who meet eligibility.
ii. It Must be hidden for guests/ ineligible users.
iii. The entry point Should communicate that the check is free and is a soft enquiry that does not affect the user's score.

b. Consent & Data Capture

i. The app Must capture explicit, affirmative consent before any vendor call. Consent Must be OFF by default (unchecked); the primary CTA Must remain disabled until consent is given.
ii. The exact consent string sent to the vendor Must be: "**I explicitly consent to the collection, processing, and verification of my data for**

authentication, KYC, and compliance purposes." This string Must be shown/available to the user at the point of consent.

iii. BoltPe Must record consent server-side with timestamp, user ID, and the consent text/ version for audit.

iv. The details form Must collect: first name, last name, PAN, date of birth, mobile number, email, gender, PIN code. Fields available from BoltPe profile/KYC Should be prefilled and editable.

v. The mobile number Must equal the account's registered mobile (OTP is delivered only there). If prefilled, it Should be read-only or clearly re-verified.

vi. All fields Must be validated client-side before enabling submit.

c. OTP Generation & Verification

i. On submit, the backend Must call the vendor genOtp endpoint with the mapped payload. Credentials (clientId, secretKey) Must be held server-side and never shipped in the mobile client.

ii. On successful OTP dispatch, the app Must move to the OTP entry screen and start a resend cooldown timer.

iii. The app Must let the user enter the OTP and Must verify it via the vendor before fetching the score. (Verify endpoint/ Reference Token). The app Must support Resend OTP after a cooldown (recommend 30s), with a capped number of resends. (Maximum 3 OTPs | 2 OTPs after the primary one)

iv. The app must cap OTP verification attempts and handle lockout gracefully.

v. OTP Must have an expiry (Message: OTP Expired | OTP shall be valid for 10 minutes)

d. Score Fetch & Display

i. On successful OTP verification, the backend Must retrieve the bureau response and extract result.SCORE.FCIREXScore as the credit score.

ii. The score screen Must display: the numeric score, the band label, and a short plain-language interpretation. A visual gauge Should be used (design open).

iii. The screen Must show report metadata: report date/time (result.CreditProfileHeader.ReportDate/ ReportTime) and report number.

iv. The screen Should surface 2 - 4 summary highlights: total/ active/ closed accounts, total outstanding, and recent enquiries.

v. If code == 200 but no score/ accounts are present, the app Must show the No-hit state, not an error.

e. Credit Report & Download

i. The app Must let the user download the credit report as a PDF generated from the vendor response.

ii. The report PDF Must include a masked identity header, score + band, account summary, per-account details, enquiry (CAPS) summary, and a generated-on timestamp + disclaimer.
iii. Sensitive identifiers (PAN, full account numbers, full mobile) Must be masked in the on-screen and PDF output, consistent with the vendor's masked response.
iv. The app Should allow share/ save of the PDF via the OS share sheet.
v. No-hit handling:
    1. When the bureau has no record for the identity, the app Must show a clear "**No Credit History Found**" state with guidance, and Must not offer a report download.

9. Credit Score Bands

Band	Range	Meaning	Color
Poor	300–579	Limited or troubled history; approvals hard, rates high.	**Red**
Fair	580–669	Below average; some approvals, often on stricter terms.	**Orange**
Good	670–739	Acceptable to most lenders; reasonable terms.	**Lite Green**
Very Good	740–799	Strong profile; good approval odds and rates.	**Green**
Excellent	800–900	Top tier; best approval odds and pricing.	**Deep Green**

- ***Please Note:***
    - ***Map the 300–900 range onto a gauge/ dial. Band cutoffs (579/ 669/ 739/ 799) define the color stops.***
    - ***Show the numeric score prominently, the band label beneath, and the band's one-line meaning.***
    - ***Colors above are guidance; final palette is Design's call, but bands must be visually distinguishable and accessible.***

10. Conditions

- Feature is available only to authenticated app users whose registered mobile matches the number used (Application User Only).
- No vendor call may occur before explicit consent is captured and persisted.
- No score/ Report may be fetched before successful OTP verification.
- Vendor credentials live only on BoltPe servers; all vendor calls are backend-proxied.
- PII in transit and at rest must be masked in UI/ PDF and encrypted in storage; PAN/ OTP/ secrets never logged in plain text.
- The check is a soft enquiry and must be described as not affecting the user's score.
- Rate limiting: cap score pulls per user per period (recommend 1 free pull/ 24h; confirm vendor billing model) to control cost and abuse.
- Data retention:
    - Define TTL for cached report data and comply with applicable data-protection norms.

    - Re-consent on each new pull.
- If Match_result.Exact_match == "**N**", flag the report as a possible partial/ near match and show a caution note.

---

11. Error Cases & Behaviour

- **Case:** Validation failure
    - **Trigger:** Field fails format check
    - **System Behaviour:** Block submit; highlight field
    - **Outcome:** Inline error, fix & retry
- **Case:** Consent missing
    - **Trigger:** Consent unchecked
    - **System Behaviour:** Keep CTA disabled
    - **Outcome:** Prompt to consent
- **Case:** OTP send failed
    - **Trigger:** genOtp non-200/ vendor error
    - **System Behaviour:** Do not advance; allow retry
    - **Outcome:** "**Couldn't send OTP, Please Try Again**"
- **Case:** Invalid OTP
    - **Trigger:** Wrong code entered
    - **System Behaviour:** Increment attempt counter
    - **Outcome:** "**Incorrect Code**" + 2 attempts left
- **Case:** Expired OTP
    - **Trigger:** OTP past TTL
    - **System Behaviour:** Invalidate; offer resend
    - **Outcome:** "**Code Expired**" | "**Resend**" Button to be activated.
- **Case:** Max OTP attempts
    - **Trigger:** Attempts exceeded
    - **System Behaviour:** Lock flow for cooldown
    - **Outcome:** "Too many tries, Please try again later"
        - Cooling Period: 30 Minutes
- **Case:** Auth Error
    - **Trigger:** 401/ 403 from vendor (bad clientId/ secretKey)
    - **System Behaviour:** Fail closed; alert on-call; do not expose keys
    - **Outcome:** Generic "**Temporary Issue**"
- **Case:** Rate limited
    - **Trigger:** 429 from vendor or BoltPe cap hit
    - **System Behaviour:** Backoff
    - **Outcome:** "**You've reached the limit, Please Try Again Later**"
- **Case:** Vendor 5xx / timeout
    - **Trigger:** Server error / no response
    - **System Behaviour:** Retry w/ backoff (bounded); then fail
    - **Outcome:** "**Service Busy, Please Try Again Later**" + Retry

- **Case:** Network offline
    - **Trigger:** No connectivity
    - **System Behaviour:** Detect; hold request
    - **Outcome:** Offline banner; auto-retry
- **Case:** Malformed response
    - **Trigger:** JSON invalid/ schema mismatch
    - **System Behaviour:** Reject; log; treat as error
    - **Outcome:** Generic Error + Retry
- **Case:** No bureau record
    - **Trigger:** 200 but no SCORE/ accounts
    - **System Behaviour:** Route to No-hit state
    - **Outcome:** "**No Credit History Found**"
- **Case:** Report gen failed
    - **Trigger:** PDF build error
    - **System Behaviour:** Retry generation; keep score view
    - **Outcome:** "**Couldn't Build Report, Please Retry**"

---

12. Edge Case & Handling

- **Thin file/ No history**
    - **Handling:**
        - Code 200 but empty CAIS + no SCORE >> No-hit state; no report download; guidance on building history.
- **Partial/ Near Identity Match**
    - **Handling:** Exact_match = "**N**" >> show caution banner; allow user to review masked identity; consider blocking report if confidence low (confirm rule with vendor).
- **Score present but zero accounts**
    - **Handling:** Show score with a note that limited tradeline data is available.
- **Empty/ Blank fields in response**
    - **Handling:** Vendor returns "" for many fields; render as "**Not Reported**"; never show blank or "**Undefined**" (note sample contains literal "**undefined**" in Last_Name; sanitize).
- "**Undefined" / "?" literals**
    - **Handling:** Treat literal "**Undefined**" and "**?**" as no-data; map to "Not reported" in UI/ PDF.
- **OTP Autofill/ Paste**
    - **Handling:** Support OS OTP autofill and paste of 6-digit code.
- **User backgrounds app mid-OTP**
    - **Handling:** Preserve OTP timer/ state on resume; if expired, prompt resend.
- **Duplicate submit/ double tap**
    - **Handling:** Debounce; idempotency key on backend to avoid duplicate vendor calls & double billing.
- **Mobile entered does not match with registered number**
    - **Handling:** Block at validation; OTP would not reach the user.

- **Very High/ Low score boundary**
    - **Handling:** Handle exact cutoffs (e.g., 800 = Excellent, 579 = Poor) per Section 7 inclusive ranges.
- **Large Report/ Many Tradelines**
    - **Handling:** Paginate on-screen; PDF handles N accounts without layout break.
- **Slow vendor (>timeout)**
    - **Handling:** Show processing state with a bounded timeout; then offer retry without re-entering data.
- **Currency/ Locale**
    - **Handling:** Amounts are INR; format with Indian digit grouping (Example: 55,143).
- **Consent withdrawn later**
    - **Handling:** Provide a path (support) to withdraw consent and delete cached report data.
- **Repeated pulls (abuse)**
    - **Handling:** Enforce per-user cap and show remaining allowance.

---

13. Non-Functional Requirements

- **Security & Privacy**
    - Vendor credentials (clientId, secretKey) stored in a server-side secret manager; never in the app binary, logs, or analytics.
    - All traffic over TLS. PII encrypted at rest. PAN, OTP, and secrets never logged in plaintext; mask in logs.
    - On-screen and PDF outputs display masked PAN, account numbers (last 4), mobile, and email.
    - Consent recorded with user ID, timestamp, and consent version for audit.
    - Access to stored reports restricted to the owning user; server-side authorization on every fetch.
- **Performance & Reliability**
    - Median consent-to-score under 30s; graceful loading states beyond that.
    - Bounded retries with exponential backoff on vendor 5xx/ timeouts.
    - Idempotency keys to prevent duplicate vendor calls on retries/ double-taps.
- **Compliance**
    - Follow applicable Indian data-protection norms and bureau/ vendor contractual terms for pulling and storing credit data.
    - Retention & deletion policy for report data defined and enforced.
    - Clear disclosure that the pull is a soft enquiry and does not impact the score.
- **Accessibility**
    - Score band conveyed by label + value, not color alone (color-blind safe).
    - Screen-reader labels for score, band, and key report figures; adequate tap targets on OTP entry.

---

14. Analytics & Instrumentation

→ **Event:** cs_entry_viewed
- **When:** Entry point rendered

→ **Event:** cs_flow_started
- **When:** User taps to begin

→ **Event:** cs_consent_given
- **When:** Consent toggled on & submitted

→ **Event:** cs_otp_requested
- **When:** genOtp called successfully

→ **Event:** cs_otp_verified / cs_otp_failed
- **When:** OTP verify outcome (+ reason)

→ **Event:** cs_score_viewed
- **When:** Score screen shown (+ band, no raw score PII policy per legal)

→ **Event:** cs_no_hit
- **When:** No bureau record

→ **Event:** cs_report_downloaded
- **When:** PDF Downloaded/ Shared

→ **Event:** cs_error
- **When:** Any error state (+ case code)

---

15. Overall Dependencies

- OTP verification endpoint + how the score/ report is retrieved post-OTP (reference token, second call, or same call after verify). Only the genOtp endpoint was provided.
  - **Owner:** Vendor/ Backend
- Accepted values/ casing for gender and any other enum fields.
  - **Owner:** Vendor
- Data dictionary for coded fields: Account_Type, Account_Status, Portfolio_Type, Enquiry_Reason, State, Asset_Classification.
  - **Owner:** Vendor
- Billing model:
  - Per OTP Vs per-successful-pull; behaviour on failures; free-tier caps.
    - **Owner:** Vendor/ Product
- Data retention/deletion policy and consent-withdrawal handling.
  - **Owner:** Legal/ Product
- Vendor rate limits, OTP TTL, resend limits, and error-code catalogue.
  - **Owner:** Vendor
- Masking policy: which fields the vendor pre-masks vs. which BoltPe must mask.
  - **Owner:** Vendor/ Security
